

Website scanned <https://github.com>
Date 04 July 2026 · 15:41

71
out of 100

Needs attention

Overall security posture based on all checks run.

Assessment Scope & Objective

This assessment evaluated the public-facing web presence of **<https://github.com>** against a set of common, high-impact web security weaknesses. The objective was to give the site owner a clear, prioritized understanding of their current security posture and the practical steps needed to improve it. Testing was non-intrusive and limited to information the site returns to any ordinary visitor.

Executive Summary

Security summary for <https://github.com>

Overall score: 71/100 (Needs attention)

Your website is reasonably safe but has some gaps worth closing. None are emergencies, but they add up.

We found 5 issue(s) to address:

1. [Medium] Exposed: Apache server-status

Why it matters: Exposes live server activity and visitor details. Found at /server-status.

2. [Medium] Cookie '_octo' missing the HttpOnly flag

Why it matters: Without 'HttpOnly', scripts on the page can read this cookie, making session theft easier if the site is ever compromised by injected code.

3. [Low] Software disclosed via 'Server' header

Why it matters: The site reveals it runs 'github.com'. No version shown, but naming the software still helps

attackers.

4. [Low] robots.txt hints at sensitive areas

Why it matters: robots.txt mentions paths like: login. This file is public and can point attackers toward interesting areas.

5. [Low] 1 email address(es) exposed in the page

Why it matters: Addresses like you@domain.com are visible in the page and can be harvested for phishing or spam.

What you're already doing right:

- Site uses HTTPS
- Header present: Strict-Transport-Security
- Header present: Content-Security-Policy
- Header present: X-Frame-Options
- Header present: X-Content-Type-Options
- Header present: Referrer-Policy
- HTTP correctly redirects to HTTPS
- Certificate is valid and current
- Modern encryption protocol in use (TLSv1.3)
- security.txt is present
- No risky CORS policy detected
- SPF record is present
- DMARC record is present

Fix these first (most important at the top):

1. Exposed: Apache server-status
2. Cookie '_octo' missing the HttpOnly flag
3. Software disclosed via 'Server' header

Every issue above is fixable, and you've taken the right first step by checking. Address them one at a time.

Understanding the Severity Ratings

Critical	A weakness that could lead to full compromise; address immediately.
High	A serious weakness that a motivated attacker could exploit; address promptly.
Medium	A meaningful gap that increases risk; should be scheduled for correction.
Low	A minor issue with limited impact; worth tidying up.
Info	An observation or a control already working correctly; no action required.

Issues Found

Severity	Finding	Check
Medium	Exposed: Apache server-status	Security Misconfiguration
Medium	Cookie '_octo' missing the HttpOnly flag	Cookie & Session Security
Low	Software disclosed via 'Server' header	Software Version & Outdated Components
Low	robots.txt hints at sensitive areas	HTTP Methods & Web Hygiene
Low	1 email address(es) exposed in the page	Information Leakage

What's Working Well

- ✓ Site uses HTTPS
- ✓ Header present: Strict-Transport-Security
- ✓ Header present: Content-Security-Policy
- ✓ Header present: X-Frame-Options
- ✓ Header present: X-Content-Type-Options
- ✓ Header present: Referrer-Policy
- ✓ HTTP correctly redirects to HTTPS
- ✓ Certificate is valid and current
- ✓ Modern encryption protocol in use (TLSv1.3)
- ✓ security.txt is present
- ✓ No risky CORS policy detected
- ✓ SPF record is present
- ✓ DMARC record is present

How to Fix These Issues

1. Exposed: Apache server-status

Restrict '/server-status' to localhost only in your Apache configuration.

2. Cookie '_octo' missing the HttpOnly flag

Set the 'HttpOnly' attribute on the '_octo' cookie so browser scripts cannot read it.

3. Software disclosed via 'Server' header

Configure your web server to hide software names and versions (Apache: 'ServerTokens Prod'; nginx: 'server_tokens off;'), and keep the software itself updated to the latest version.

4. robots.txt hints at sensitive areas

Avoid listing sensitive paths in robots.txt; protect them with real access controls instead.

5. 1 email address(es) exposed in the page

Consider a contact form instead of publishing raw email addresses, or obfuscate them.

Limitations

This report is based on automated, non-intrusive testing and reflects the state of the site at the time of the scan. It is intended as a practical starting point, not a substitute for a full manual security audit. Automated checks can miss issues that require human judgement, such as business-logic flaws or context-specific weaknesses. The findings should be treated as an input to your wider decisions about security, and re-testing is recommended after any fixes are applied.

Generated by PurpEye — automated website security scanning.
This report reflects passive checks and is a starting point, not a full audit.